

Rejestr360 — jak to działa teraz

Pełny przegląd produktu, Core i pętli KRS po wdrożeniach z 23–24 sierpnia 2026. Odpowiedź na pytanie: czy silnik zmian jest OK, czy jeszcze coś bym zmienił.

Data	24 sierpnia 2026, wieczór CEST
Produkt	ulepszonyrejstrio · main @ 0e43e427 · PR #88
Core	polish-company-data-core · main @ 1f9ae11e
Live	https://www.rejestr360.pl · 165 289 profili KRS
Zakres	Tylko odczyt. Zero commitów, zero zmian Vercel / Supabase / DNS.

Werdykt w jednym zdaniu

Silnik „CO się zmieniło” (Delta KRS v2) jest wdrożony i generalnie dobry. Narodowej pętli „KTO się dziś ruszył” (Biuletyn MS) nadal nie ma. Watchlista godzinna działa, ale porównuje odpis z cache 6 godzin — to jedyny twardy błąd w pętli KRS.

Trzy warstwy — nie mylić

A. Biuletyn MS = kto się ruszył w całym kraju (NIE MA). B. Odpis + fingerprint = co konkretnie się zmieniło (JEST, PR #88). C. Watchlista = obserwowane spółki, cron co godzinę (JEST, ale cache i throughput).

1. Co zostało wdrożone od poprzedniego audytu

Od audytu z rana 24.08 na main weszły trzy duże pakiety: Search + Trust, rozdział odczytu monitoringu od zapisów M2M, hardening auth/legal oraz — wieczorem — cały silnik Delta KRS v2. Core dostał indeksowane RPC wyszukiwania. Narodowego Biuletynu nikt nie zaczął.

Obszar	Stan rano 24.08	Stan teraz	Ocena
Delta KRS v2 (atomy zdarzeń)	spec / v1 agregaty	PR #88 zmergowany 16:07 UTC. 20+ rodzajów: prezes, zarząd, prokura, wspólnicy, CRBR, relacje, nazwa	WDROŻONE — dobre
Świeża nazwa KRS w cronie	brak	getFreshKrsLegalName() z cache: no-store, tylko na ścieżce monitoringu	WDROŻONE
Stabilizator masek Open API	ryzyko false-positive	named → masked nie jest usunięciem. Test pokrywa prezesa.	WDROŻONE
Rozdział health / zapis	GET /api/monitoring-health mógł pisać	Publiczny health tylko czyta. Zapis: POST /api/internal/monitoring-refresh + sekret crona. Edge zaktualizowany.	WDROŻONE
Wyszukiwarka Core	ILIKE / wolne	pl_company_suggest_v1 + pl_company_search_v1, trigram, normalized_name_key, partial-resilient	WDROŻONE
Auth / Turnstile / legal w kodzie	brak	Turnstile + throttling. Polityka i regulamin w kodzie, ale live = 404 (brak env operatora).	KOD TAK, LIVE NIE
Plany publiczne	były	FREE 0 zł / PRO i BUSINESS „płatności w przygotowaniu”; limity 5 / 100 / 1000 firm	Bez zmian
Narodowy Biuletyn KRS	specyfikacja, zero kodu	Nadal 0 plików, 0 tabel pl_krs_delta_*, 0 jobów w Core. Worker = wyłącznie GUS range_scan.	NIE WDROŻONE

2. Jak działa pętla KRS — to, co naprawdę jest w kodzie

Warstwa B — silnik semantyczny (OK)

Gdy system ma dwa stany tej samej spółki, Delta v2 atomizuje różnicę. Nie woła Biuletynu. Nie zgaduje tożsamości. Nie alertuje na baseline. To jest właściwy silnik „co się zmieniło” i taksonomii nie przebudowywałbym.

- Tożsamość: company_name_change, legal_form_change, registered_address_change, status_change, activity_change.
- Władza: representation_rule_change; board_member_added / removed / role_changed / status_changed; proxy_*. Rola z „prezes” idzie w tytule jako zmiana prezesa.
- Własność KRS: shareholder_added / removed / shareholding_changed. Spółka-wspólnik kluczem KRS; osoba — znormalizowaną nazwą.
- CRBR i relacje: beneficial_owner_*, crbr_representative_*, corporate_relation_*, capital_change, financial_filing, registry_signal.
- Migracja v1→v2: pierwsze przejście neutralizuje nowe pola (nazwa, wspólnicy), żeby nie wygenerować fałszywych alertów z pustego „before”.
- Maski Open API: jeśli nazwana osoba staje się „Dane osoby zanonimizowane...”, poprzedni skład zostaje. To ograniczenie źródła, nie zgadywanie.

Pliki: src/lib/delta/{core,krs,crbr,relations,history,legacy,utils}.ts, src/lib/monitoring-hardening.ts, tests/delta-krs-v2.test.mjs, docs/delta-krs-v2.md.

Warstwa C — watchlista godzinna (jest, z luką)

pg_cron co godzinę woła Edge Function monitoring-refresh. Worker weryfikuje SHA-256 sekretu z Vault, bierze należne podmioty (FOR UPDATE SKIP LOCKED, lease 5 min, batch 12, concurrency 3). Dla każdego KRS:

- POST https://rejestr360.pl/api/internal/monitoring-refresh?krs=... z cron sekretem. Fail-closed: zły sekret → 401. GET → 405.
- Równolegle: getKrsSnapshot (odpis), getFreshKrsLegalName (nazwa, no-store), getCrbrSnapshot.
- captureCompanyMonitoringSnapshot(..., { persist: true }) — baseline albo semantyczny diff do pl_source_snapshots / pl_detected_changes.
- Po 2 min safe-lag: GET /api/monitoring-change-feed i fan-out do prywatnych skrzynek (unique watchlist_id + core_change_id).
- Profil spółki NIE zapisuje już monitoringu. Publiczny /api/monitoring-health tylko czyta, captureScheduledAfterResponse: false.

Luka, której v2 nie naprawia

getKrsSnapshot() nadal ma next: { revalidate: 21600 } — cache Next.js na 6 godzin. Godzinny cron często porównuje STARY zarząd ze STARYM zarządem. Świeży no-store jest tylko dla nazwy. Prezes na obserwowanej spółce może zniknąć na kilka godzin albo w ogóle w danym oknie. To jedyny twardy błąd w „wdrożonej pętli KRS”.

Warstwa A — Biuletyn narodowy (nie ma)

Oficjalne GET /api/Krs/Biuletyn/{YYYY-MM-DD} działa — 22.08.2026 zwróciło 500 numerów KRS (możliwy cap i duplikaty). W obu repozytoriach: zero kodu, zero tabel pl_krs_delta_days / pl_krs_delta_queue, zero workflow. Core worker.py to nadal wyłącznie checkpointowany GUS BIR range_scan (tożsamość NIP/REGON/nazwa, nie prezes). GUS nie jest detektorem zmian w zarządzie.

Konsekwencja: spółka, której nikt nie ma na watchliście, nie ma cyklu odpisu. Zmiana prezesa w Polsce poza obserwowanymi firmami jest dziś niewidoczna. To nie jest recenzja v2 — v2 nie miał tego robić. To brakująca warstwa z specyfikacji delty.

3. Czy v2 jest OK, czy bym coś zmienił?

Taksonomii, fingerprintów, zasady baseline i stabilizatora named→masked nie przebudowywałbym. To jest właściwy silnik. Testy pokrywają prezesa, v1→v2 i maskowanie. Routing do Decision Drift / Inbox jest spójny. Zmieniłbym pięć rzeczy wokół niego — nie sam silnik.

P0 — zrobiłbym teraz

P0-1. no-store na odpisie w cronie. getKrsSnapshot() na ścieżce /api/internal/monitoring-refresh musi iść z cache: "no-store" (albo osobna funkcja getFreshKrsSnapshot). Profil publiczny może zostać na 6 h. Przy okazji: jeden odpis na cykl, nie dwa (dziś snapshot cache + identity no-store = podwójne wołanie MS).

P0-2. Legal na produkcji. /polityka-prywatnosci i /regulamin istnieją, ale wołają notFound() gdy brakuje któregośkolwiek REJESTR360_OPERATOR_*. Na live jest 404, footer pokazuje „wersja beta”. Kod jest — brakuje pięciu zmiennych na Vercel. Konto z Turnstile bez administratora w stopce to ryzyko RODO, nie kosmetyka.

P1 — zanim sprzedasz monitoring

P1-1. Change-feed bez auth. GET /api/monitoring-change-feed?krs=...&after;=...&through;=... jest publiczny. Zwraca tytuły i szczegóły zmian (mogą być nazwiska). Cron powinien używać tego samego x-ri-cron-secret co refresh.

P1-2. Throughput crona. Batch 12 / godzinę. FREE (5 firm) — OK, cykl ~godzina. PRO (100) — pierwsza pełna runda ~8 h. BUSINESS (1000) — ~83 h, czyli ~3,5 dnia. Copy na /plany tego nie uniesie. Albo częstszy cron + większy batch, albo Biuletyn jako indeks „kto dziś”, a watchlista zostaje SLA dla obserwowanych.

P1-3. Narodowy Biuletyn (Job A/B). Nadal jedyna droga, żeby złapać prezesa spółki, której nikt nie obserwuje. Nie mieszać z GUS range_scan. Nie drugi detektor — ta sama captureCompanyMonitoringSnapshot. Kolejka nie idzie do FREE inbox. Watchlista godzinna zostaje SLA. Uwaga: Biuletyn 22.08 zwrócił dokładnie 500 pozycji — jeśli to cap, Job A musi paginować albo użyć biuletynu godzinowego.

P2 — jakość, nie blocker

- Stabilizator za grubo: jeśli JAKIKOLWIEK członek zarządu jest zamaskowany, przenoszony jest CAŁY poprzedni skład. Realna zmiana + jedna maska = cisza. Cieńszy wariant: maska per osoba, nie per organ.
- Wspólnicy tylko z wspólnicySpzoo — komandytowe, akcyjne, przekształcenia wypadają.
- personKey = sama nazwa. Dwie osoby o tym samym imieniu i nazwisku w zarządzie zderzają się.
- Docs vs kod: MONITORING_CORE.md nadal opisuje v1 i after() na health. WATCHLIST_ORCHESTRATOR.md nadal mówi, że cron woła publiczny monitoring-health. ARCHITECTURE.md nadal obiecuje ILIKE.
- DEFAULT_CORE_SUPABASE_URL zahardkodowany w company-search.ts i monitoring-core.ts (rfauagtdvgantxljerzf). Działa, ale pomyłka env-a milczy.
- SHA sekretu crona w źródle jako fallback. Hash nie wystarczy do logowania, ale fail-closed bez env byłby czystszy.

4. Mapa infrastruktury (stan faktyczny)

Warstwa	Co tam jest	Uwaga
Przeglądarka	Next.js 16 App Router, React 19, Vercel. SEO na Server Components. Search = TanStack Query.	Brak service_role w kliencie.
BFF	Route handlers. Core i Product DB tylko z serwera.	Właściwy wzorzec.
Product DB	ygtddpcaramtdlpbeqxxy — auth, plany, ri_watchlists, ri_monitor_subjects, ri_alert_events, Vault, pg_cron.	Granica Core vs Product trzymana.
Core DB	rfauagtdvgantxljerzf — pl_companies, aliasy, pl_source_snapshots, pl_detected_changes, finanse, osoby CRBR, RPC search.	RLS deny-by-default. Brak tabel Biuletynu.
Worker Core	GUS BIR range_scan + Finansial XML inbox (ZIP, XAdES, adaptery v2).	To bootstrap tożsamości i sprawozdań, nie delta KRS.
Źródła live	KRS Open API odpis (P, potem S, timeout 9 s), CRBR, GUS BIR.	Odpis profilu cache 6 h; nazwa w cronie no-store.
Auth	Supabase Auth + Turnstile + rate limit na login/register/reset.	Legal operator env nieustawiony → 404.

.env.production w git trzyma wyłącznie klucze publiczne (publishable). To jest OK. CORE_SUPABASE_SERVICE_ROLE_KEY zostaje server-only.

5. Live site, 24.08 wieczór

Powierzchnia	Stan
https://rejestr360.pl	Działa. Hero: wyszukiwarka firm i osób. Deklaracja 165 289 profili KRS.
/plany	LIVE. FREE 0 zł (5 firm, 3 analizy/mies.). PRO 100 firm, BUSINESS 1000. Płatności „w przygotowaniu”.
/logowanie /rejestracja	LIVE. Turnstile w kodzie (widget może nie być czytelny w pierwszym screenie).
/polityka-prywatnosci /regulamin	404. Kod jest, getRejestr360LegalOperator() zwraca null bez pełnego zestawu env.
/api/health	{"status":"ok"}
Monitoring health	Publiczny GET nie zapisuje (naprawione). 404 na nieistniejący w Core KRS jest spójny z companyFound: false.
Biuletyn MS	GET /api/Krs/Biuletyn/2026-08-22 = tablica ~500 KRS. Produkt nie konsumuje.

6. Bezpieczeństwo — delta vs poprzedni audyt

Temat	Było	Jest	Zostaje
Zapis monitoringu z internetu	P0: GET health pisał	Rozdzielone; persist tylko M2M	OK
Sekrety w git	P0 naprawione wcześniej	.env.production = publishable	OK
service_role w przeglądarce	nie	nie	OK
RLS Core	deny-by-default	bez zmian	OK
Auth brute-force	słabe	Turnstile + throttling	Lepiej
Legal / RODO	404	kod jest, env nie	LIVE 404
Change-feed	publiczny	nadal publiczny GET	P1
Odpis w cronie	cache 6 h	nadal cache 6 h	P0

7. Produkt, pieniądze, konkurencja

Nipli i podobne katalogi mają już „prawie całą bazę”. Rejestr360 nie wygra liczbą rekordów. Wygra, jeśli zmiana prezesa / zasady reprezentacji / beneficjenta jest zdarzeniem z dowodem (before → after, źródło, okno detekcji), a nie wierszem w tabeli. Delta v2 jest pierwszym prawdziwym klinem pod tę obietnicę. Bez warstwy A klin działa tylko na watchliście, i to z opóźnieniem cache.

Plan	Obietnica	Ryzyko uczciwości
FREE	3 analizy / 5 firm monitoringu / 0 zł	Uczciwe, jeśli cron ogarnia 5 KRS/h — ogarnia.
PRO	100 firm, pełne finanse, materiały decyzyjne	Płatności nieaktywne. 100 firm przy batch 12 = ~8 h cykl. Na granicy.
BUSINESS	1000 firm + zespół	Dziś niewykonalne godzinowym SLA. Albo Biuletyn, albo inny scheduler. Nie sprzedawać zanim to nie wróci.

Core pozostaje wartością niezależną od SaaS: 165 tys. i cel 1,2 mln + sprawozdania. Nawet jeśli Rejestr360 nie sprzedaje PRO, ta baza zasila inne produkty. Tego nie ruszać i nie mieszać z detekcją zmian.

8. Szczera ocena szans

Scenariusz	Szansa	Warunek
Core jako baza do innych produktów	wysoka	Dociągnąć 1,2 mln + inbox finansowy. To już idzie. Nie blokować GUS-em delty KRS.
SaaS monitoringu (klin vs Nipli)	średnia, rosnąca	v2 jest klinem. Żeby był wiarygodny: no-store odpis, legal live, Biuletyn albo uczciwy throughput, płatności.
Katalog „mamy wszystkie spółki” vs Nipli	niska	Nie iść w to. Oni mają katalog. Wy macie (macie mieć) zdarzenie i dowód.
Sprzedaż BUSINESS 1000 firm „na godziny” dziś	bliska zero	Matematyka crona tego nie uniesie. Najpierw warstwa A albo inny scheduler.
Poprzedni audyt mówił: Core ma wartość, SaaS jeszcze nie konkurencyjny. Dziś SaaS zrobił prawdziwy krok (v2 + rozdział zapisu + search RPC + auth). Nadal nie jest produktem, który można uczciwie sprzedać jako „wylecimy Wam prezesa w całym KRS”. Można uczciwie powiedzieć: „obserwujcie spółki — powiemy, CO się zmieniło, z dowodem”. Po P0-1 to zdanie będzie prawdziwe. Po warstwie A będzie prawdziwe także bez watchlisty.		

9. Co zrobię, gdy powiesz „tak” — kolejność

Nic z tego nie commitowałem. Kolejność to moja rekomendacja, nie menu.

#	Priorytet	Zmiana	Gdzie
1	P0	getKrsSnapshot({cache:"no-store"}) na ścieżce monitoringu; jeden odpis na cykl, nie dwa	ulepszonyrejstrio
2	P0	Ustawić REJESTR360_OPERATOR_* na Vercel, żeby legal przestał być 404 (to env, nie kod)	Vercel
3	P1	Auth machine-to-machine na /api/monitoring-change-feed	ulepszonyrejstrio
4	P1	Scheduler: większy batch / częstszy cron albo uczciwy limit w copy planów	product + Edge
5	P1	Job A/B Biuletyn w Core — po P0, inaczej narodowa kolejka też będzie porównywać cache	polish-company-data-core
6	P2	Stabilizator per osoba; wspólnicy poza sp. z o.o.; docs vs kod; env Core URL	oba repo

Czego nie robić

Nie budować drugiego detektora zmian. Nie mieszać GUS range_scan z odpisem/CRBR. Nie wsadzać narodowego firehose do FREE inbox. Nie przebudowywać taksonomii v2. Nie commitować Biuletynu, dopóki odpis na ścieżce monitoringu nie jest no-store.

Aneks A. SHA i kontrakt

Fakt	Wartość
Produkt SHA	0e43e427 — Merge PR #88 feat: ship Delta KRS v2, 2026-08-24 16:07:39Z
Core SHA	1f9ae11e — perf: restore indexed company suggest plan, 2026-08-24 06:18:01Z
Product DB	ygtddpcaramtdlpbeqxy.supabase.co
Core DB	rfauagtdvgantxljerzf.supabase.co
KRS odpis	https://api-krs.ms.gov.pl/api/krs/OdpisAktualny/{krs}?rejestr=PJS
KRS biuletyn	https://api-krs.ms.gov.pl/api/Krs/Biuletyn/{YYYY-MM-DD} — działa, produkt nie czyta
Zapis monitoringu	POST /api/internal/monitoring-refresh (x-ri-cron-secret)
Odczyt monitoringu	GET /api/monitoring-health (bez persist)
Testy delty	tests/delta-krs-v2.test.mjs — prezes, v1→v2, maska, no-store nazwy
CI produktu	npm test + typecheck + production build

Aneks B. Źródła tej oceny

Kod: ulepszonyrejstrio main (docs/delta-krs-v2.md, src/lib/delta/*, src/app/api/internal/monitoring-refresh/route.ts, src/app/api/monitoring-health/route.ts, src/app/api/monitoring-change-feed/route.ts, src/lib/data/krs.ts, src/lib/data/krs-identity.ts, src/lib/data/monitoring-core.ts, supabase-product/functions/monitoring-refresh/index.ts, src/lib/legal/operator.ts, src/app/polityka-prywatnosci/page.tsx).

Core: worker.py (wyłącznie range_scan), drzewo supabase/migrations — brak pl_krs_delta_*, workflows: krs-master-autopilot, financial-inbox. Live: rejestr360.pl, /plany, /polityka-prywatnosci (404), /api/health, Biuletyn MS 2026-08-22.

Ten dokument zastępuje doraźny werdykt z czatu z 24.08 wieczór. Nie zastępuje specyfikacji architektury delty (osobny PDF). Nie jest ofertą wdrożenia — czekam na zgodę punkt po punkcie.